

Atividade Prática 1: Scan Automático & Pipeline DevSecOps

Módulo de Infraestrutura e Integração Contínua

Objetivo da Atividade: Projetar e documentar o fluxo completo de uma esteira de CI/CD orientada à segurança (Shift Left). Vocês deverão estruturar desde o recebimento do código até o monitoramento em produção, justificando as ferramentas e etapas adotadas.

| Requisitos do Projeto

1 Integração e Entrega Contínuas (CI/CD)

Definir qual orquestrador será utilizado (ex: GitHub Actions, GitLab CI, Jenkins) e desenhar as etapas (jobs) da pipeline. O fluxo deve prever bloqueios (Quality Gates) caso testes de segurança ou qualidade falhem.

2 Containerização (Docker)

Planejar a criação da imagem Docker da aplicação. O plano deve contemplar boas práticas de construção (ex: multi-stage build) e definir onde esta imagem será hospedada (Registry) de forma segura.

3 Infraestrutura como Código (Terraform)

Estruturar como os recursos de nuvem serão provisionados utilizando Terraform. O fluxo deve incluir testes automatizados na infraestrutura antes de aplicar as mudanças no ambiente de produção.

4 Observabilidade e Monitoramento

Estabelecer como será feito o monitoramento contínuo em produção. Deve-se prever a coleta de logs, métricas da infraestrutura e como a equipe será alertada em caso de comportamentos anômalos.

| Stack de Ferramentas de Segurança (Obrigatório)

O plano deve incorporar nativamente a cultura DevSecOps. Vocês devem selecionar e encaixar no fluxo as seguintes ferramentas discutidas em sala:

Categoria	Ferramentas Sugeridas	Fase da Pipeline
Proteção de Segredos	Gitleaks ou GitGuardian	Pré-commit ou Push inicial
Análise Estática (SAST)	SonarQube, Snyk ou Semgrep	Fase de Build / Integração
Análise de Imagens & IaC	Trivy ou Checkov	Pós-Build / Antes do Deploy
Análise Dinâmica (DAST)	OWASP ZAP	Ambiente de Teste / Staging

Entregáveis Esperados

- **Diagrama de Fluxo:** Uma representação visual da pipeline, desde o commit no repositório até o deploy e monitoramento.
- **Documento de Arquitetura:** Um descritivo curto justificando as escolhas das ferramentas de CI/CD, Container e IaC, e explicando exatamente em qual momento cada ferramenta de segurança bloqueia a esteira em caso de falha.